UNIVERSITY OF LONDON

BSc EXAMINATION 2022

For Internal Students of
Royal Holloway

DO NOT TURN OVER UNTIL TOLD TO BEGIN

IY3501: Security Management

for FIRST SIT/RESIT CANDIDATES

Time Allowed: **TWO hours**

Answer **THREE** questions.
No credit will be given for attempting any further questions.

Important Copyright Notice
This exam paper has been made available in electronic form
strictly for the educational benefit of current Royal Holloway students
on the course of study in question.
No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

©Royal Holloway, University of London 2022

Question 1. There are two main approaches to defining information security in the context of security management: the threat-based approach and the objective-based approach.

(a) Briefly describe what is meant by the terms threat-based approach and objective-based approach. Illustrate your answer by making reference to **ONE** example threat and **ONE** example objective. [8 marks]

(b) Define the following terms:

(i) Vulnerability [2 marks]

(ii) Security violation [2 marks]

(iii) Attacker [2 marks]

(c) Briefly describe, providing **ONE** example for each case, the **THREE** main security violations that are generally considered under the threat-based approach. [9 marks]

(d) Imagine you own a company that has developed an app that enables customers to order a food delivery.

(i) Identify **ONE** business goal of your company. [2 marks]

(ii) Describe **THREE** possible vulnerabilities that may affect the app and explain how they could put the identified business goal at risk. [9 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 2. (a) Identify and briefly outline the main steps in the risk management process. [18 marks]

(b) The following security breach has been widely reported:

Yahoo has been fined £ 250,000 by the UK Information Commissioner's Office (ICO) over a data breach affecting more than 500 million users which took place in 2014. Around eight million of the affected accounts were believed to belong to people in the UK. The flaws which led to the breach were not quickly discovered or addressed, and the incident only was reported two years later. Hackers had stolen personal information, which included names, emails, unencrypted security questions and answers.

The ICO said Yahoo had failed to take appropriate measures to protect the data. "The failings our investigation identified are not what we expect or will accept from a company processing significant volumes of personal data," wrote deputy commissioner of operations James Dipple-Johnstone. "Yahoo had ample opportunity to implement appropriate measures, and potentially stop UK citizens' data being compromised."

The ICO's investigation found that the firm failed to ensure that its Yahoo-owned data processor "complied with the appropriate data protection standards" and the firm did not ensure that the credentials of employees with access to customer data were monitored.

Identify and explain **TWO** possible areas of weakness in the Yahoo risk management process that this breach may highlight. [16 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 3. (a) ISO/IEC 27001 and ISO/IEC 27002 are widely used information security management standards. Summarise the scope of both of these standards. [6 marks]

(b) Outline the process by which an organisation might become ISO/IEC 27001 certified. [3 marks]

(c) Explain the role of the Statement of Applicability in relation to ISO/IEC 27001 and ISO/IEC 27002. [3 marks]

(d) It is a fundamental requirement of ISO/IEC 27001 that an organisation should create a high-level security policy. Suppose you are starting a company.

(i) Outline the components of a suitable high-level security policy for this new organisation, specifying some main information security objectives for the company. [16 marks]

(ii) Give **TWO** examples of low-level security policies that your organisation might adopt to support the high-level policy. In each case, justify why such a policy might be adopted, with reference to the business context. [6 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 4. (a) With references to an example in each case, distinguish between an information security event and an information security incident. [9 marks]

(b) Identify and briefly describe the **FIVE** main phases of managing an information security incident. [15 marks]

(c) Describe **TWO** ways in which the incident management process can inform the risk management process. [10 marks]

END

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.